

Vulnerability Assessment Report

10th September 2026

System Description

The server hardware consists of a powerful CPU processor and 128GB of memory. It runs on the latest version of Linux operating system and hosts a MySQL database management system. It is configured with a stable network connection using IPv4 addresses and interacts with other servers on the network. Security measures include SSL/TLS encrypted connections.

Scope

The scope of this vulnerability assessment relates to the current access controls of the system. The assessment will cover a period of three months, from June 20XX to August 20XX. [NIST SP 800-30 Rev. 1](#) is used to guide the risk analysis of the information system.

Purpose

The database server supports e-commerce and marketing activities by storing customer, campaign, and analytic data used to identify potential customers and to guide business decisions. Because employees work remotely, unauthorized access could expose sensitive business and customer information. Securing the server protects confidentiality, integrity, and trust while supporting reliable operations. If the server were disabled or compromised, employees could lose access to critical data and marketing activities could be disrupted.

Risk Assessment

Threat source	Threat event	Likelihood	Severity	Risk
Hacker	Obtain sensitive information via exfiltration	1	3	3
Employee	Disrupt mission-critical operations	2	3	6
Customer	Alter/Delete critical information	1	3	3

Approach

I selected hacker, employee, and customer threat sources because the database is publicly accessible and these users or groups can interact with information in the system. The events reflect unauthorized disclosure, alteration or deletion, and operational disruption. Hacker activity receives the highest likelihood because public access increases exposure to attacks. Employee and customer events have lower likelihood but can still affect day-to-day operations.

Remediation Strategy

Restrict database access so only authenticated and authorized users can connect, using least privilege and role-based access controls. Require strong passwords and multi-factor authentication, and maintain auditing and accounting logs to detect and investigate misuse. Remove direct public access through IP allow-listing or a secure remote-access path for approved employees. Protect data in motion with TLS and use defense in depth through network filtering and continuous monitoring to reduce exfiltration, alteration, and denial-of-service risks.